

Ransomware: Operators, Tactics, Defenses

The modern ransomware business

RaaS (Ransomware-as-a-Service): developers (affiliates) lease ransomware; operators do access; negotiators/exfil teams split proceeds (e.g., LockBit, BlackCat, Conti-hold)

Double extortion: encrypt AND threaten to leak / already exfiltrate data

Triple leverage: add DDoS on top, or pressure customers/regulators

Initial access economy: purchased footholds (Broker/access sellers), VPNs without MFA, exposed RDP

Typical TTP sequence

Initial access: phishing lure, vuln VPN, RDP brute

Foothold + C2: beacon; side moves

Privilege elevation: Kerberoast/domain account (often within hours)

Lateral + destroy backups: net use/psexec/windows task spread; kill/delete backup volumes (VSS, tapes, cloud snapshots!)

Exfil staging (double extortion) – often via FTP/cloud to attacker

Detonation: encrypt all, drop ransom note

Negotiation + leak site (public shame shaming)

Defense spine (assume breach)

Backups immutable & offline: 3-2-1 (3 copies, 2 media, 1 offsite), tested restore quarterly; cloud snapshots versioned + protected from deletion

MFA everywhere: stops the #1 access vector (VPN/RDP)

Segment + least privilege: stops lateral speed; tier-0 admin secured

EDR + detection: respond to beaconing BEFORE encryption

IR runbook + tabletop: rehearse restore; decision-makers know 'pay or not' policy

User training: recognize the lure

If infected

Contain: disconnect target(s) at switch level

Preserve evidence (forensic images)

Engage IR + law enforcement/mitigation; check ransomware response groups

Decide/ext to restore from clean immutable backups

Ransomware wins on speed of movement vs speed of detection. Every hour of dwell time you deny the attacker is an hour your restorers win.

[← Malware Taxonomy](#)

[Fileless & 'Living Off the Lan...](#)